

CUESTIONARIO / LEVANTAMIENTO INICIAL

Validación del problema

A.1 Gestión desorganizada de auditorías

1. ¿Cómo se organiza actualmente el trabajo cuando una persona lleva varias auditorías al mismo tiempo?

Cada Pentester suele llevar su propio orden (notas, carpetas o documentos separados por auditoría), sin un formato o proceso común entre personas del equipo.

2. ¿Existe algún estándar o plantilla común para gestionar una auditoría, o cada quien define su propio método?

No existe un estándar único impuesto por la organización; cada Pentester suele adaptar plantillas propias o heredadas de auditorías anteriores.

3. ¿Qué problemas ha causado, si alguno, la falta de un método común?

Dificultad para que otra persona retome una auditoría en curso, y falta de consistencia en el formato de los hallazgos entre auditorías distintas.

A.2 Información distribuida en diferentes herramientas

4. ¿Qué herramientas se usan actualmente para registrar hallazgos?

Combinación de Word, Markdown y hojas de cálculo, dependiendo de la preferencia de cada Pentester y del tipo de auditoría.

5. ¿Se ha usado más de una herramienta dentro de la misma auditoría o entre auditorías distintas?

Sí, es común alternar herramientas incluso dentro de una misma auditoría (por ejemplo, notas en Markdown y reporte final en Word).

6. ¿Esto ha generado dificultades al momento de consolidar información?

Sí, principalmente al unificar formato y estructura antes de entregar el reporte final al cliente.

A.3 Falta de centralización

7. ¿Existe hoy alguna forma de consultar, en un solo lugar, el estado de todas las auditorías activas?

No existe una vista centralizada; el estado se conoce preguntando directamente a quien lleva cada auditoría.

8. Si no existe, ¿cómo se obtiene esa información actualmente?

De forma informal, mediante comunicación directa (correo, mensajería) entre los involucrados.

A.4 Elaboración manual de reportes

9. ¿Cómo se construye actualmente el reporte final de una auditoría?

Recopilando manualmente los hallazgos registrados durante la auditoría y dándoles formato en un documento final.

10. ¿Cuánto tiempo aproximado toma consolidar y dar formato al reporte final?

Representa una parte considerable del tiempo total de la auditoría. Esta cifra debe precisarse más adelante con datos reales.

11. ¿Qué parte de ese proceso es más propensa a errores o retrabajo?

La unificación de formato entre hallazgos registrados de manera distinta por cada Pentester.

A.5 Falta de métricas históricas

12. ¿Existe actualmente alguna forma de consultar tendencias históricas?

No existe una fuente centralizada; el análisis de tendencias, si se hace, se realiza manualmente revisando reportes anteriores.

13. ¿Sería útil contar con esa información? ¿Para qué se usaría?

Podría ser útil para identificar vulnerabilidades recurrentes en un cliente o sector, y para justificar recomendaciones con datos históricos.

Usuarios del sistema

14. ¿Cuáles de los siguientes roles interactuarían realmente con el sistema: Pentester, Administrador, Líder de auditoría, Cliente?

Pentester, Administrador, Líder de auditoría y Cliente tienen una interacción clara y distinta.

15. ¿Falta algún rol en la lista?

No se identifica ninguno adicional.

16. Para cada rol, ¿qué necesita ver o hacer que los demás roles no necesiten?

- Pentester: registrar hallazgos y evidencias de sus auditorías asignadas.
- Líder de auditoría: asignar Pentesters, supervisar el estado general de las auditorías, revisar y validar hallazgos.
- Administrador: gestionar usuarios y configuración general del sistema, sin intervenir en la operación de las auditorías.
- Cliente: consultar el estado o el reporte final de su propia auditoría.

Funcionalidades

17. ¿Cuáles funcionalidades son imprescindibles (MVP)?

Gestión de auditorías y gestión de hallazgos, por ser las más básicas. Evidencias y reportes están directamente ligadas a los problemas de dispersión de información y elaboración manual de reportes.

18. ¿Cuáles podrían dejarse para una fase posterior?

Métricas históricas, ya que depende de tener primero datos acumulados de auditorías gestionadas por el propio sistema.

19. ¿Existe alguna funcionalidad no listada que considere necesaria?

No se identifica ninguna adicional por el momento.

20. Para cada funcionalidad imprescindible, ¿qué problema resuelve?

- Gestión de auditorías → gestión desorganizada, falta de centralización.
- Gestión de hallazgos → gestión desorganizada, dispersión de herramientas.
- Evidencias → dispersión de herramientas.
- Reportes → elaboración manual de reportes.

Contexto adicional

21. ¿Ha usado o conoce herramientas como Faraday o PlexTrac?

No se cuenta con experiencia de uso verificada por el momento.

22. ¿Existe alguna restricción importante que el sistema debería respetar?

Es razonable esperar confidencialidad sobre hallazgos y evidencias de auditorías, dado el dominio de seguridad informática, aunque el nivel exacto de restricción aún no está definido.

23. ¿Hay algo que el sistema no debería intentar hacer?

No debería intentar reemplazar herramientas especializadas de escaneo o explotación; su alcance es de gestión y centralización, no de ejecución técnica de pruebas.